



SECURITY ASSESSMENT LOOP Protocol Entry- point review

September 15, 2026

Limited-Scope Review (no score issued)

BLADE POOL

RISK ANALYSIS | LOOP Protocol.

■ Classifications of Manual Risk Results

Note: Risk classifications follow CVSS v4.0 standards (<https://www.first.org/cvss/v4.0/specification-document>). Contract security metrics are verified through GoPlus API token scanner technology, which provides real-time validation of contract parameters including

Classification	CVSS Range	Description
 Critical	9.0 - 10.0	Critical vulnerabilities that pose immediate and severe risks requiring urgent attention.
 High	7.0 - 8.9	High-priority issues that could lead to significant security breaches or financial loss.
 Medium	4.0 - 6.9	Medium-severity findings that should be addressed to improve contract security.
 Low	0.1 - 3.9	Low-risk items or best practice suggestions with minimal security impact.
 Informational	0.0	Informational findings about detected functions or contract features.

■ Manual Code Review Risk Results

Contract Security	Description
 Buy Tax	N/A
 Sale Tax	N/A
 Cannot Buy	N/A
 Cannot Sale	N/A
 Max Tax	N/A
 Modify Tax	N/A
 Fee Check	Not Applicable
 Is Honeypot?	Not Applicable
 Trading Cooldown	Not Applicable
 Enable Trade?	N/A

Contract Security	Description
 Pause Transfer?	N/A
 Max Tx?	N/A
 Is Anti Whale?	N/A
 Is Anti Bot?	N/A
 Is Blacklist?	N/A
 Blacklist Check	N/A
 Is Whitelist?	N/A
 Can Mint?	Out of scope
 Is Proxy?	N/A
 Can Take Ownership?	Out of scope (upgrade authority not verified)
 Hidden Owner?	N/A
 Owner	Program upgrade authority (verify on-chain)
 Self Destruct?	N/A
 External Call?	Raydium CPI (in handlers - out of scope)
 Other?	Solana Anchor staking + referral program; only the entry-point module (lib.rs) was reviewed.
 Holders	N/A
 Audit Confidence	Not applicable - limited-scope review
 Authority Check	Not reviewed (out of scope)
 Freeze Check	N/A

Overview of identified vulnerabilities and risks. See the full report for detailed methodology and recommendations.



LOOP Protocol

Executive Summary

TYPES

DeFi

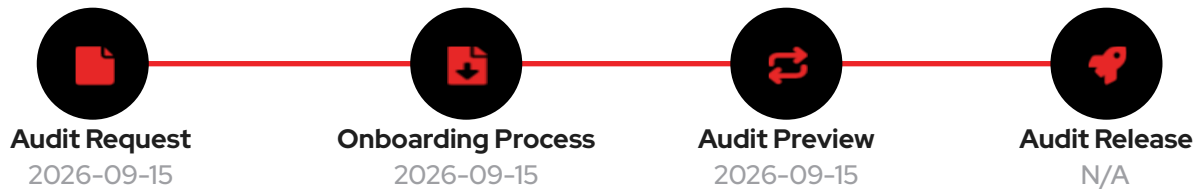
ECOSYSTEM

Solana

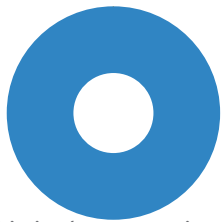
LANGUAGE

Rust

Timeline



Vulnerability Summary



1

Total Findings

0

Resolved

1

Pending

1

Unresolved

Limited-scope review: only the program entry-point module (src/lib.rs) was reviewed. The framework checks depend on the instruction-handler modules, which were out of scope and NOT assessed. One informational observation recorded; no security score or pass/fail issued.

Severity	Resolution Status	Description
0 Critical		Immediate danger. Can lead to loss of user funds, unauthorized access, or full system compromise.
0 High		Significant risk that should be addressed urgently to prevent exploitation or financial loss.
0 Medium		Moderate risk that can lead to issues if combined with other weaknesses; should be addressed.
0 Low		Minor concern or best-practice deviation with limited direct security impact.
1 Informational	0 Resolved, 1 Pending	Not a vulnerability - code-quality, documentation, or optimization suggestions.

PROJECT OVERVIEW | LOOP Protocol.

Token Summary

Parameter	Result
Address	81EUhaSVy8edRdyZ2TSrZSYa72U2tKY8zTDURsUAtRT6
Name	LOOP Protocol
Token Tracker	LOOP Protocol (LOOP)
Decimals	N/A
Supply	N/A (program)
Platform	Solana
Compiler	Anchor (Rust / Solana BPF)
Contract Name	staking (program entry-point)
Optimization	No
LicenseType	See source header
Language	Rust
Codebase	https://x.com/loop_protocol_

TECHNICAL FINDINGS

Smart contract security audits classify risks into several categories: Critical, High, Medium, Low, and Informational. These classifications help assess the severity and potential impact of vulnerabilities found in smart contracts.

Classification of Risk

Severity	CVSS Range	Description
 Critical	9.0 - 10.0	Immediate danger. Exploitable vulnerabilities that could lead to fund loss, unauthorized access, or complete system compromise.
 High	7.0 - 8.9	Significant security risk. Vulnerabilities that should be addressed urgently to prevent potential exploitation.
 Medium	4.0 - 6.9	Moderate security risk. Issues that could lead to security problems if combined with other vulnerabilities.
 Low	0.1 - 3.9	Minor security concern. Best practice violations or low-impact issues.
 Informational	0.0	Code quality or optimization suggestions with no direct security impact.

Detailed Security Findings

Each finding lists its severity, CVSS, location and description, the affected source excerpt (verbatim from the verified Blockscout source), our recommendation, mitigation, references, and a suggested fix where the remediation is code-expressible.

LOOP-01 | Entry-Point Router Is Well-Formed; Verify declare_id & Remove Unused Import..

Category	Severity	CVSS	Location	Status
Code Quality	 Informational	0.0	src/lib.rs: src/lib.rs (mod staking)	 Informational

Description

The provided module is a standard, correctly structured Anchor entry-point: it declares the program id and each instruction forwards its context and parameters to the corresponding handler in the instructions module, with no business logic, account validation, arithmetic or CPIs performed at this layer. As such the entry-point itself introduces no exploitable behaviour. Two minor observations: (1) `declare_id!` ("81EUhaSVy8edRdyZ2TSrZSYa72U2tKY8zTDURsUAAtRT6") must exactly match the deployed program's address/keypair or the program will reject all instructions with `DeclaredProgramIdMismatch` - verify this against the live deployment; (2) `use anchor_lang::solana_program::program::get_return_data;` is imported inside the program module but is not used within `lib.rs` (a dead import in this file / compiler warning).

Recommendation

Confirm the declared program id matches the deployed program, and remove the unused `get_return_data` import from `lib.rs` (or move it to the handler that uses it). Neither is a vulnerability; both are code-hygiene items.

Mitigation

Entry-point is a clean dispatcher; the two items above are informational only.

References:

N/A

FINDINGS

In this document, we present the findings and results of the smart contract security audit. The identified vulnerabilities, weaknesses, and potential risks are outlined, along with recommendations for mitigating these issues. It is crucial for the team to address these findings promptly to enhance the security and trustworthiness of the smart contract code.

Severity	Found	Pending	Resolved
 Critical	0	0	0
 High	0	0	0
 Medium	0	0	0
 Low	0	0	0
 Informational	1	1	0
Total	1	1	0

In a smart contract, a technical finding summary refers to a compilation of identified issues or vulnerabilities discovered during a security audit. These findings can range from coding errors and logical flaws to potential security risks. It is crucial for the project owner to thoroughly review each identified item and take necessary actions to resolve them. By carefully examining the technical finding summary, the project owner can gain insights into the weaknesses or potential threats present in the smart contract. They should prioritize addressing these issues promptly to mitigate any risks associated with the contract's security. Neglecting to address any identified item in the security audit can expose the smart contract to significant risks. Unresolved vulnerabilities can be exploited by malicious actors, potentially leading to financial losses, data breaches, or other detrimental consequences. To ensure the integrity and security of the smart contract, the project owner should engage in a comprehensive review process. This involves understanding the nature and severity of each identified item, consulting with experts if needed, and implementing appropriate fixes or enhancements. Regularly updating and maintaining the smart contract's codebase is also essential to address any emerging security concerns. By diligently reviewing and resolving all identified items in the technical finding summary, the project owner can significantly reduce the risks associated with the smart contract and enhance its overall security posture.

SOCIAL MEDIA CHECKS | LOOP Protocol.

Social Media	URL	Result
Website	https://x.com/loop_protocol_	Confirmed
Telegram		N/A
Twitter	https://x.com/loop_protocol_	Confirmed
Facebook		N/A
Reddit	N/A	N/A
Instagram	N/A	N/A
CoinGecko		N/A
Github	N/A	N/A
CMC		N/A
Email		Contact
Other		N/A

From a security assessment standpoint, inspecting a project's social media presence is essential. It enables the evaluation of the project's reputation, credibility, and trustworthiness within the community. By analyzing the content shared, engagement levels, and the response to any security-related incidents, one can assess the project's commitment to security practices and its ability to handle potential threats.

Social Media Information Notes:

Auditor Notes: Project X/Twitter (x.com/loop_protocol_) provided by the client.

Project Owner Notes: Limited-scope engagement.

Assessment Results**Final Audit Score LOOP.**

Review	Score
Reviewed scope	Program entry-point module (lib.rs)
Security score	Not issued (limited-scope review)

This engagement was a limited-scope review. Only the program entry-point module (src/lib.rs) was provided and reviewed. The instruction-handler modules that implement the protocol's logic - account validation, cross-program invocations, arithmetic, reward accounting, referral and pricing economics, privileged roles and denial-of-service surface - were not provided and were not reviewed. For this reason no numeric security score and no pass or fail status is issued, and no assurance is given regarding the security of LOOP Protocol as a whole. A full audit with a score requires the complete program source.

LIMITED-SCOPE REVIEW

No security score and no pass/fail status is issued. Only the program entry-point module (lib.rs) was reviewed; the instruction-handler modules were out of scope, so no assurance is given for the protocol as a whole.

Important Notes for LOOP

SCOPE LIMITATION - PLEASE READ FIRST.

This document is a LIMITED-SCOPE REVIEW of LOOP Protocol, not a full security audit.

Only one file was provided and reviewed: `src/lib.rs`, the Anchor program entry-point (the instruction router). It declares the program id and forwards each instruction to a handler in the instructions module.

The modules that contain the protocol's actual logic were NOT provided and were NOT reviewed: `instructions/*.rs` (initialize, admin, operator, `set_a9_price`, `buy_a8`, stake, register, and the `claim_*` family), `state.rs`, `utils.rs`, `raydium.rs`, `constants.rs` and `error.rs`.

Because of this, NO security score and NO pass/fail status is issued, and no assurance is given about the security of LOOP Protocol as a whole. The controls that determine whether the protocol is safe - Anchor account validation (signer, owner, `has_one`, PDA seeds and bump), cross-program invocation safety (including the Raydium integration), integer overflow and rounding, reward accounting and double-claim protection, referral and pricing economics, privileged-role and fund-redirection risk, and denial-of-service - all live in the handler modules and were outside this review.

Result of the reviewed scope: the entry-point module is a standard, correctly structured Anchor router. It performs no business logic, account validation, arithmetic or CPIs itself, so it introduces no exploitable behaviour on its own. One informational observation is recorded: confirm that the declared program id matches the deployed program, and remove the unused `get_return_data` import from `lib.rs`. Neither is a vulnerability.

To obtain a full LOOP Protocol security audit with a score, provide the complete program source (all instruction handlers, state, utils, raydium, constants and error modules), the Cargo manifest, and the deployed program address.

This review reflects the information made available at the time of writing and does not constitute financial or investment advice.

I Appendix

Finding Categories

Centralization / Privilege

Centralization / Privilege findings refer to either feature logic or implementation of components that act against the nature of decentralization, such as explicit ownership or specialized access roles in combination with a mechanism to relocate funds.

Gas Optimization

Gas Optimization findings do not affect the functionality of the code but generate different, more optimal EVM opcodes resulting in a reduction in the total gas cost of a transaction.

Logical Issue

Logical Issue findings detail a fault in the logic of the linked code, such as an incorrect notion of how block.timestamp works.

Control Flow

Control Flow findings concern the access control imposed on functions, such as owner-only functions being invocable by anyone under certain circumstances.

Volatile Code

Volatile Code findings refer to segments of code that behave unexpectedly in certain edge cases that may result in a vulnerability.

Coding Style

Coding Style findings usually do not affect the generated byte-code but rather comment on how to make the codebase more legible and, as a result, easily maintainable.

Inconsistency

Inconsistency findings refer to functions that should seemingly behave similarly yet contain different code, such as a constructor assignment imposing different require statements on the input variables than a setter function.

Coding Best Practices

ERC 20 Coding Standards are a set of rules that each developer should follow to ensure the code meets a set of criteria and is readable by all developers.

Disclaimer

Scope. This report documents the results of a security assessment and smart contract audit performed by Bladepool / CFG NINJA (the "Auditor") for the project specified in this report. The assessment covers only the deliverables and code expressly listed in the engagement; any changes, integrations, or subsequent deployments are outside the scope.

No Warranty. The Auditor performs the assessment using industry-standard practices but makes no representations or warranties, express or implied, including any warranty of merchantability, fitness for a particular purpose, or non-infringement. The Auditor does not guarantee that the audited code is free of bugs, vulnerabilities, or exploitable issues.

Limitation of Liability. To the maximum extent permitted by law, the Auditor and its affiliates, officers, employees, agents, and contractors shall not be liable for any indirect, incidental, special, consequential, or punitive damages, or for any loss of profits, revenue, data, or business opportunities, arising out of or related to the assessment, even if advised of the possibility of such damages. The Auditor's aggregate liability for direct damages is limited to the fees paid for the audit engagement.

Client Responsibility. The project owner/client retains sole responsibility for all decisions and actions taken in connection with the audited code, including fixing identified issues, deploying code to any environment, and applying security mitigations. The Auditor's recommendations are advisory; implementation and verification of fixes are the client's responsibility.

Third-Party Tools and Services. The Auditor may use third-party tools, services, or automated scanners as part of the assessment. Use of such tools is without warranty; the Auditor is not responsible for defects, failures, or inaccuracies arising from third-party services.

Confidentiality and Data Security. The Auditor will treat non-public client information as confidential. However, the Auditor cannot guarantee absolute security for data transmitted over the internet or third-party platforms. Client should take reasonable precautions to protect sensitive information.

Not Financial, Legal, or Investment Advice. The assessment is a technical security review only and is not financial, legal, tax, or investment advice. Clients should consult appropriate professionals for those matters.

Ownership and Governance Notes. If ownership is transferred, held by a multisig, or controlled by a governance contract, the client should document and disclose those arrangements; the Auditor's report reflects the ownership state observed during the engagement but may not reflect subsequent changes.

Governing Law and Counsel. This engagement and any disputes arising from it shall be governed by the laws agreed in the engagement terms. Clients are advised to seek legal counsel before relying on or publishing the report.

Acceptance. By proceeding with this engagement or using this report, the client acknowledges and accepts these terms.

